PQC DAILY STUDY SERIES

Stateful vs. Stateless Hash-Based Signatures: Understanding SLH-DSA

Day 52 | Category: PQC Foundational Concepts Date: 2026-11-07 | DAILY MONITORING

Stateful vs. Stateless Hash-Based Signatures: A Deep Dive into SLH-DSA (SPHINCS+)

Hash-based signature schemes are a major category of post-quantum algorithms, known for their strong security proofs based on the properties of cryptographic hash functions. However, they come in two main flavors: stateful and stateless. Understanding the difference is critical for their correct and secure implementation. Today, we explore this distinction and why the stateless approach of SLH-DSA (FIPS 205) is crucial for modern internet protocols.

What are Stateful Hash-Based Signatures?

Stateful schemes, such as Leighton-Micali Signatures (LMS) and eXtended Merkle Signature Scheme (XMSS), require the signer to maintain a state. This state is typically a counter or index that tracks which one-time private key has been used. The core principle is that **each one-time key must be used only once.**

- **How it works:** A large number of one-time keys are generated, and their corresponding public keys are combined into a Merkle tree structure to create a single top-level public key. Each signature is generated with a different one-time key.
- **The Critical Flaw:** If the state is not perfectly managed (e.g., due to VM rollbacks, concurrent signing operations, or bugs) and a one-time key is reused, an attacker can forge signatures. This "one-time" rule is an unforgiving foot-gun.

> **The Danger of State Mismanagement**
>
> Reusing a private key in a stateful hash-based signature scheme is a catastrophic failure. It allows an attacker to derive the private key and forge signatures at will. This makes them unsuitable for many modern, distributed, and high-concurrency environments where maintaining a perfect, synchronized state is a major challenge.

The Stateless Revolution: SLH-DSA (SPHINCS+)

SLH-DSA (standardized by NIST in FIPS 205 and also known as SPHINCS+) is a **stateless** hash-based signature scheme. It elegantly solves the state management problem by removing the need for the signer to track which keys have been used.

- **How it works:** Instead of relying on a sequential counter, SLH-DSA uses a pseudo-random process to select the one-time key for each signature. The selection is determined by the message being signed and a randomizer. This means that for a given message, the signing process is deterministic, but different messages will use different parts of the key structure.
- **The Key Advantage:** The signer no longer needs to maintain a persistent state across multiple signing operations. Each signature is self-contained. This makes SLH-DSA far more robust and suitable for real-world deployment in complex systems.

Comparison: Stateful vs. Stateless

Metric	Stateful (LMS, XMSS)	Stateless (SLH-DSA/SPHINCS+)
State Management	Required and critical for security. Key reuse leads to catastrophic failure.	Not required. Each signature is independent.
Signature Size	Generally smaller (e.g., ~2.5 KB for XMSS).	Significantly larger (e.g., ~8 KB for SLH-DSA-SHAKE-128f).
Signing Speed	Faster, as it involves fewer hash computations per signature.	Slower, as it requires generating a more complex structure for each signature.
Robustness & Safety	Fragile. Prone to implementation errors related to state.	Highly robust. Resilient to VM rollbacks and concurrency issues.
Applicability	Best for controlled environments (e.g., code signing CAs, firmware signing).	Ideal for general-purpose use in internet protocols (TLS, SSH, DNSSEC) and software signing.

Applicability to Internet Security

The robustness of stateless schemes like SLH-DSA makes them the clear choice for protecting internet protocols. Imagine a busy web server with multiple threads or processes handling TLS handshakes. Trying to synchronize a stateful counter across all of them without ever making a mistake is nearly impossible and a huge security risk.

SLH-DSA, despite its larger signature size and slower performance, provides the safety guarantee that is non-negotiable for internet-scale infrastructure. Its inclusion in the NIST PQC standards ensures that developers have a quantum-resistant digital signature algorithm that can be deployed with confidence, without the fear of state-related vulnerabilities.

Daily Quiz

1. What is the primary security risk associated with stateful hash-based signatures like XMSS?
2. How does SLH-DSA (SPHINCS+) solve the state management problem?
3. Why is a stateless signature scheme generally preferred for high-concurrency applications like a web server handling TLS connections?
